Chapter 1

Introduction to Ethical Hacking and Security Fundamentals

Theory: 2.5 Hours **Practice:** 2.5 Hours

Instructor: Dr. Brahim Ferik

Academic Year: 2026–2027

1 What Is Ethical Hacking?

Ethical hacking is the **authorized and systematic use of attacker techniques to evaluate and improve the security of digital systems**. It examines computers, networks, applications, identities, and other assets from an adversarial perspective so that weaknesses can be discovered and corrected before they are exploited maliciously [1, 2].

Three principles distinguish ethical hacking from unauthorized activity:

Authorization + Defined Scope + Defensive Purpose

Authorization is the formal permission granted by an individual or organization with legitimate authority over the systems being tested. It establishes the legal and professional basis for the engagement.

Scope defines the technical and organizational boundaries of the assessment. It identifies which systems, applications, accounts, networks, services, or locations may be tested and which assets are explicitly excluded.

Ethical hacking therefore does not begin with a scanner or exploitation framework. It begins with permission, agreed objectives, and clear operating boundaries.

Without authorization, technical expertise does not transform an action into ethical security testing.

1.1 Professional Responsibility

Ethical hackers are expected to exercise their technical capabilities in a manner that protects the client, affected users, data, and infrastructure. Professional conduct includes minimizing unnecessary disruption, preserving confidentiality, documenting actions accurately, respecting scope limitations, and reporting findings truthfully.

The principle of **minimum harm** is particularly important. A tester should obtain sufficient evidence to demonstrate a vulnerability without creating unnecessary operational risk. If a weakness has already been proven, further exploitation that could damage data or interrupt services may be unnecessary.

Responsible reporting completes the process. Communicate findings only to authorized recipients, and explain the weakness, supporting evidence, potential impact, and practical remediation measures [1].

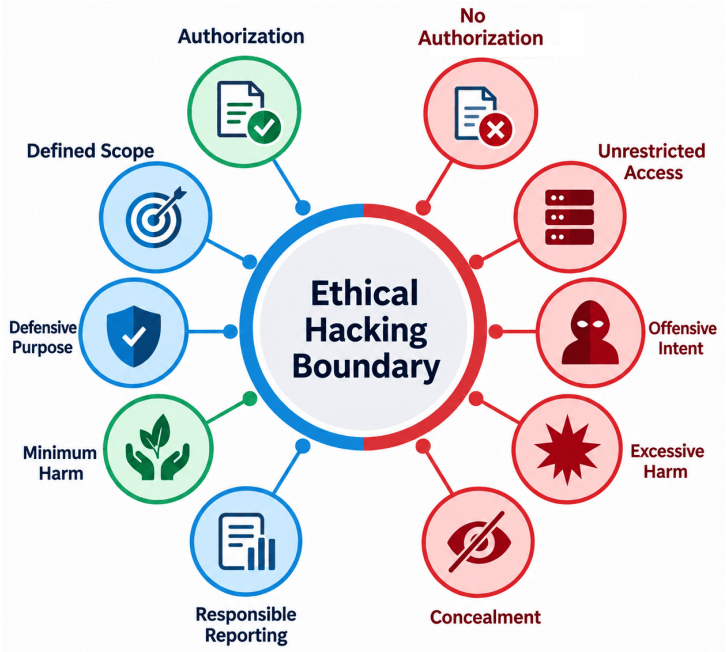


Figure 1: Authorization, defined scope, and defensive purpose distinguish ethical security testing from unauthorized hacking.

2 Core Cybersecurity Vocabulary

Ethical hacking depends on a precise understanding of several fundamental security concepts [3].

Concept	Definition
Asset	Anything of value that requires protection, including information, credentials, systems, applications, intellectual property, cloud resources, services, and organizational reputation.
Threat	A circumstance or event capable of causing harm to an asset.
Threat Actor	An individual, group, organization, or automated entity capable of carrying out harmful activity.
Vulnerability	A weakness in software, hardware, configuration, architecture, procedure, or human behavior that may be exploited to compromise security.
Exploit	A technique, sequence of actions, or piece of code that takes advantage of a vulnerability to produce unintended behavior.
Attack Vector	The path or method through which an adversary attempts to reach or compromise a target.
Risk	The possibility that a threat will exploit a vulnerability and cause harmful consequences.
Security Control	A technical, administrative, or physical safeguard intended to prevent, detect, reduce, respond to, or recover from security incidents.
Residual Risk	The level of risk that remains after security controls and mitigation measures have been implemented.

Table 1: Fundamental cybersecurity concepts.

These concepts are closely related. An organization first identifies its **assets**, then considers the **threats** and **vulnerabilities** that could affect them. A threat actor may use an **attack vector** and an **exploit** to take advantage of a weakness. The resulting likelihood and impact contribute to **risk**, which is reduced through appropriate **security controls**.

A simplified introductory model is:

$$\text{Risk} \approx \text{Likelihood} \times \text{Impact} \tag{1}$$

Because no control eliminates every possible threat, some level of residual risk usually remains.

3 The CIA Triad

The **CIA Triad** is a foundational model of information security. It organizes security objectives around three principles: **Confidentiality, Integrity, and Availability** [3].

Although modern cybersecurity also considers authenticity, accountability, privacy, and non-repudiation, the CIA Triad remains a practical starting point for understanding what security controls are designed to protect.

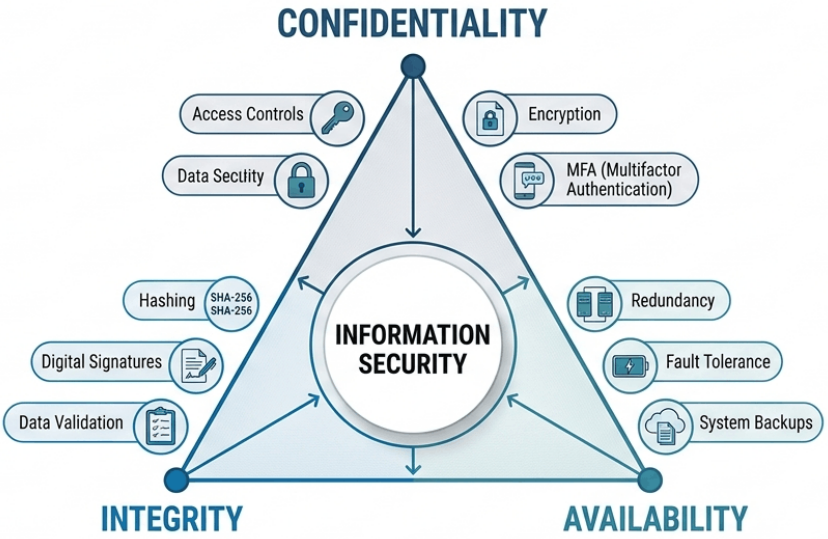


Figure 2: The CIA Triad: Confidentiality, Integrity, and Availability are foundational objectives of information security.

3.1 Confidentiality

Confidentiality ensures that information is accessible only to authorized users, processes, or systems. A confidentiality failure occurs when sensitive information is disclosed to an unauthorized party.

Typical controls include authentication, access control, encryption, file permissions, data classification, and network segmentation.

3.2 Integrity

Integrity ensures that information and systems remain accurate, complete, and protected against unauthorized or improper modification.

Integrity may be supported through cryptographic hashing, digital signatures, access permissions, audit logs, version control, and formal change-management procedures.

3.3 Availability

Availability ensures that authorized users can reliably access systems, information, and services when required.

Typical availability measures include backups, redundancy, monitoring, failover, capacity planning, patching, and disaster-recovery procedures.

3.4 Practical Example

Consider an online university grading system.

Security Event	CIA Property Affected
A student reads another student's grades	Confidentiality
A student changes a grade	Integrity
The server becomes unavailable during exams	Availability
A database is encrypted by ransomware	Availability, potentially Integrity
A password database is stolen	Confidentiality
An administrator accidentally deletes records	Integrity and Availability

Table 2: Examples of incidents mapped to the CIA Triad.

A single incident may affect more than one element of the CIA Triad.

4 Hacker Classifications and Security Teams

Hacker classifications provide a simplified way to distinguish security-related activity according to **authorization and intent**.

White Hat hackers perform authorized security testing for defensive purposes.

Gray Hat hackers may not intend to cause harm but perform security-related activity without proper authorization.

Black Hat hackers deliberately perform unauthorized activities for objectives such as theft, financial gain, disruption, or espionage [1].



Figure 3: White Hat, Gray Hat, and Black Hat classifications. Authorization and intent are the principal distinctions between these categories.

Beyond these broad labels, threat actors may include cybercriminals, malicious insiders, hacktivists, state-sponsored groups, organized criminal organizations, competitors, and opportunistic attackers. Their motivations may include financial gain, espionage, political influence, disruption, revenge, or intellectual-property theft.

4.1 Red, Blue, and Purple Teams

A **Red Team** performs authorized adversary simulation. Its purpose is to examine how effectively an organization can prevent, detect, and respond to realistic attack paths involving people, processes, and technology.

A **Blue Team** focuses on defense. Its responsibilities may include system hardening, monitoring, vulnerability management, log analysis, detection engineering, threat hunting, incident response, and recovery.

Purple Teaming connects offensive and defensive perspectives. Red Team techniques and findings are shared with defenders so that detection logic, preventive controls, and response procedures can be improved.

Red discovers → Blue detects and defends → Purple improves both sides

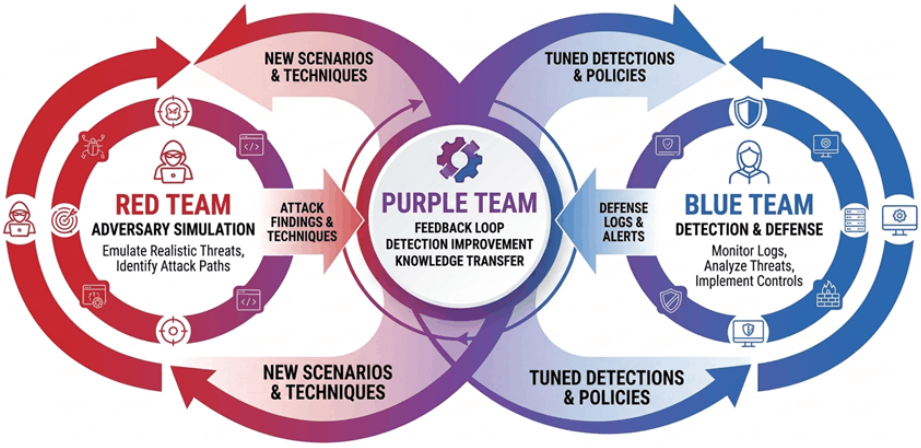


Figure 4: Red Team adversary simulation, Blue Team detection and defense, and Purple Team feedback and knowledge transfer.

5 The Modern Cyber Threat Landscape

Cybersecurity has evolved from attacks against isolated computers to operations targeting interconnected ecosystems of endpoints, cloud platforms, identities, APIs, software dependencies, and third-party services.

Modern incidents demonstrate that attackers increasingly exploit not only technical vulnerabilities but also **trust relationships, credentials, identities, software supply chains, and interconnected services**.

The growth of cloud computing, SaaS platforms, remote access, APIs, and third-party dependencies has significantly expanded the organizational **attack surface**.

5.1 Attack Surface

The attack surface is the collection of points through which an unauthorized person could attempt to enter, influence, extract information from, or disrupt a system.

An organizational attack surface may include:

- public applications and network services;
- endpoints and remote-access systems;
- user accounts and credentials;
- APIs and cloud resources;
- employees and contractors;
- software dependencies;

- service providers and trusted third parties.

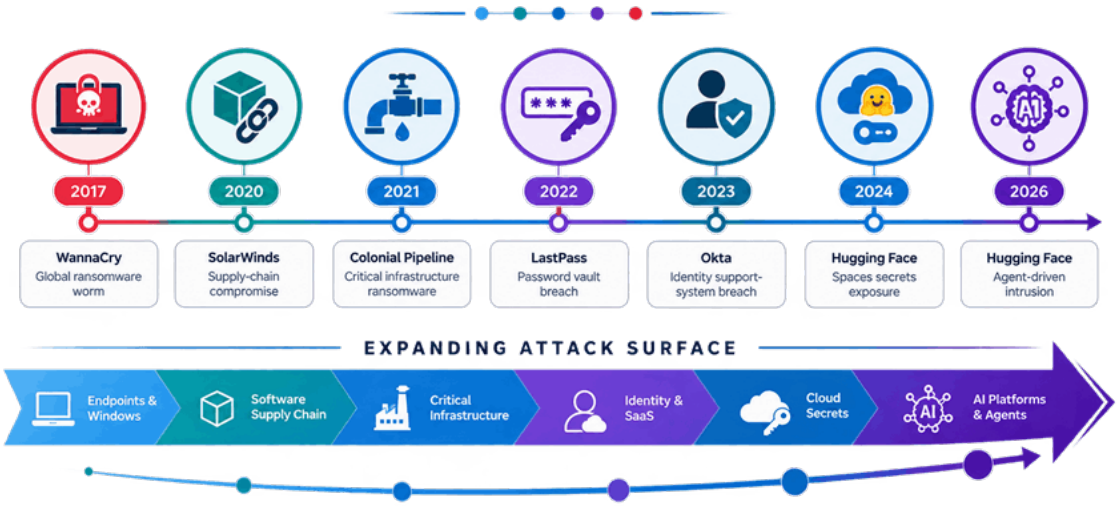


Figure 5: The evolution of modern cyberattacks from ransomware toward supply-chain, cloud, identity, and AI-platform threats [4].

5.2 Modern Attack Vectors

A **human attack vector** exploits trust, decisions, habits, or mistakes. Common examples include phishing, malicious attachments, impersonation, fraudulent support requests, and credential theft.

Network and application vectors include exposed services, insecure remote access, weak protocols, vulnerable web applications, insecure APIs, and software dependencies.

Endpoint vectors include malicious software, outdated applications, and insecure system configurations.

Cloud and identity attacks target accounts, credentials, access tokens, authentication mechanisms, sessions, permissions, and Identity and Access Management configurations.

A **supply-chain attack** compromises an organization indirectly by targeting a trusted software supplier, dependency, managed service provider, or other third party.

The modern defensive challenge can therefore be summarized as follows:

Attackers increasingly target trust relationships and identity, not merely machines.

6 Vulnerability Assessment vs. Penetration Testing

Although vulnerability assessment and penetration testing are related, they answer different security questions.

A **vulnerability assessment** asks:

"What weaknesses might exist?"

Its purpose is to identify, classify, validate, and prioritize security weaknesses across an environment. It normally provides broad coverage and may combine automated scanning with manual verification.

A **penetration test** asks:

"Can an identified weakness be used to produce meaningful security impact?"

Penetration testing goes beyond discovery by attempting controlled validation or exploitation under defined authorization. A professional test may include planning, information gathering, vulnerability analysis, controlled exploitation, impact analysis, evidence collection, remediation guidance, and reporting [2, 1].

6.1 Testing Perspectives

Penetration tests may also be categorized according to the amount of information provided to the tester.

Black Box The tester receives little or no prior information about the target.

Gray Box The tester receives limited information or credentials.

White Box The tester receives substantial internal information about the target environment.

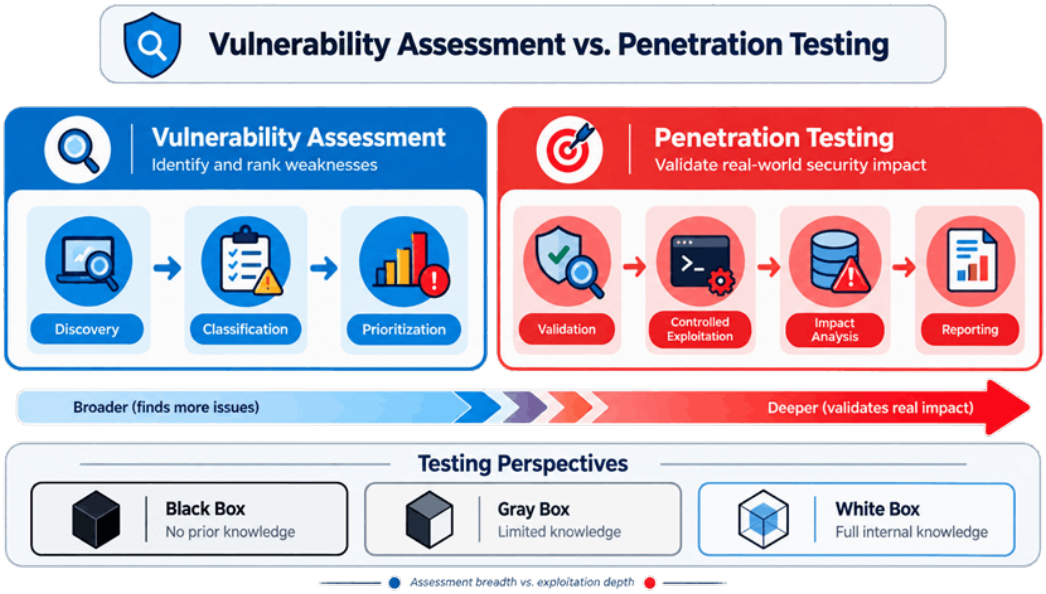


Figure 6: Vulnerability assessment emphasizes discovery, classification, and prioritization, while penetration testing extends into validation, controlled exploitation, impact analysis, and reporting [2, 1].

7 Legal, Ethical and Professional Boundaries

Technical capability does not provide legal authority. Ethical hacking must operate within formal authorization, clearly defined scope, and agreed Rules of Engagement.

A tester should know which systems may be tested, when testing may occur, which techniques are allowed, which systems are excluded, and what conditions require testing to stop.

7.1 Rules of Engagement

The **Rules of Engagement (RoE)** define how an assessment may be conducted.

Element	Purpose
Authorization	Identifies who has legitimate authority to approve the test.
Scope	Defines which systems, applications, accounts, networks, or locations may be tested.
Out-of-Scope Assets	Identifies systems or resources that must not be tested.
Testing Window	Defines when security testing may occur.
Permitted Techniques	Specifies whether activities such as social engineering, password testing, wireless testing, or exploitation are allowed.
Stop Conditions	Defines circumstances that require the assessment to pause or terminate.
Evidence Handling	Defines how screenshots, logs, credentials, network captures, and other collected data must be protected.
Communication and Reporting	Defines emergency contacts and who is authorized to receive assessment results.

Table 3: Key components of Rules of Engagement.

A well-defined RoE reduces ambiguity and helps prevent authorized security testing from creating unintended operational, contractual, or legal consequences [5].

7.2 Algerian Legal Context

Ethical hackers working in Algeria must understand that technical accessibility does not imply legal authorization.

One important Algerian legal reference is **Law No. 09-04 of 5 August 2009**, which establishes rules for preventing and combating offenses involving information and communication technologies [6].

The Algerian Penal Code also addresses attacks against automated data-processing systems. Article 394 bis, as amended by **Law No. 24-06 of 28 April 2024**, addresses fraudulent access to or remaining within such systems and provides increased penalties where data or system operation is affected [6].

For ethical hackers, the practical principle is straightforward:

Do not access, scan, manipulate, or test a system merely because it is technically reachable. Obtain authorization.

7.3 Data Protection and International Context

Algeria's **Law No. 18-07 of 10 June 2018** governs the protection of natural persons in personal-data processing and was amended and supplemented by **Law No. 25-11 of 24 July 2025** [7].

Penetration testers should therefore treat personally identifiable information discovered during an engagement as sensitive evidence.

International reference points include the European Union's **General Data Protection Regulation (GDPR)**, where applicable, and the Council of Europe's **Budapest Convention on Cybercrime** as an important framework for international cybercrime legislation and cooperation.

Legal obligations differ between jurisdictions. Professional testers must therefore understand the laws, contracts, and organizational policies applicable to each engagement.

8 Penetration Testing and Adversary Frameworks

Ethical hacking and penetration testing can be described through several complementary models. A simple five-phase hacking lifecycle helps to understand the general progression of an attack, while more formal frameworks such as PTES, the Cyber Kill Chain, and MITRE ATT&CK provide additional perspectives on professional testing, intrusion progression, and adversary behavior.

8.1 The Five Phases of Ethical Hacking

A commonly used introductory model organizes hacking activity into five phases:



Figure 7: Five phases of ethical hacking.

This model outlines how attackers progress from reconnaissance to post-compromise activity. For ethical hackers, it supports controlled simulation of relevant behaviors and helps identify opportunities where defensive controls can detect, disrupt, or stop an attack. [8].

Phase	Main Purpose	Ethical-Hacking Interpretation
Reconnaissance	Gather target information about systems, people, technologies, and external presence.	Use passive or explicitly authorized active information gathering to understand the target environment.
Scanning	Identify reachable hosts, ports, services, configurations, and potential weaknesses.	Conduct authorized technical discovery and vulnerability analysis within the approved scope.
Gaining Access	Exploit an identified weakness to access a system, application, or resource.	Perform controlled exploitation only when permitted, using minimal action to demonstrate security impact.
Maintaining Access	Preserve access to a compromised environment so an attacker can continue operating.	Test persistence or post-exploitation only when explicitly authorized and necessary to demonstrate risk.
Covering Tracks	Hide evidence of intrusion to avoid detection and conceal attacker activity.	Never destroy evidence; remove test artifacts, restore systems, and document actions under Rules of Engagement.

Table 4: The five phases of ethical hacking and their interpretation in an authorized security assessment.

The five-phase model should not be interpreted as a complete professional penetration-testing methodology. It primarily describes the progression of attacker activity.

Five Phases = Simplified Attack Progression.

For this reason, the five-phase model complements rather than replaces frameworks such as PTES.

8.2 PTES — The Testing Process

The **Penetration Testing Execution Standard (PTES)** structures penetration testing as a managed professional process.

A commonly used PTES sequence includes:

1. Pre-engagement interactions
2. Intelligence gathering
3. Threat modeling

4. Vulnerability analysis
5. Exploitation
6. Post-exploitation
7. Reporting

The key point is that exploitation is only one phase of a penetration test. Planning, analysis, validation, and communication are equally important [5].

8.3 Cyber Kill Chain — Attack Progression

The Cyber Kill Chain describes an intrusion as a sequence of stages:

1. Reconnaissance
2. Weaponization
3. Delivery
4. Exploitation
5. Installation
6. Command and Control
7. Actions on Objectives

The model helps defenders identify opportunities to interrupt an intrusion before the adversary reaches the final objective [9].

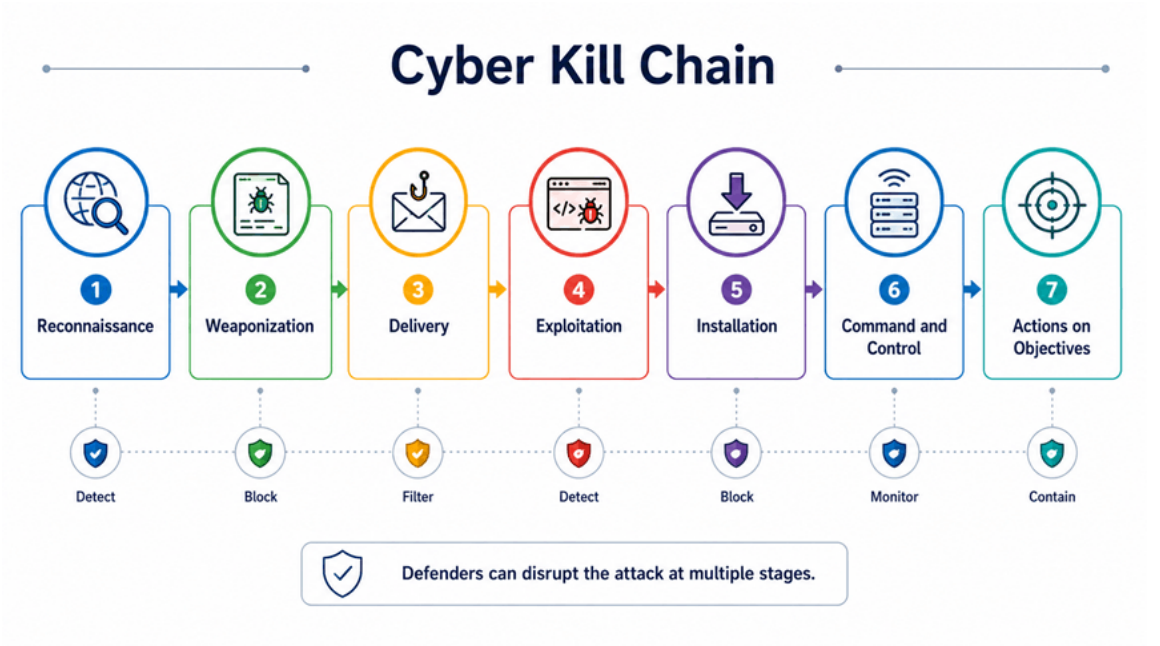


Figure 8: The seven stages of the Cyber Kill Chain and defensive opportunities for interrupting an intrusion [9].

For example, a malicious attachment may represent **Delivery**; execution of vulnerable code may represent **Exploitation**; and communication between a compromised system and attacker-controlled infrastructure may represent **Command and Control**.

The defensive lesson is:

Disrupting even one stage can break an attack chain.

8.4 MITRE ATT&CK — Adversary Behavior

MITRE ATT&CK is a structured knowledge base describing tactics and techniques observed in real-world adversary operations [10].

Within ATT&CK:

Tactic = Why

Technique = How

A **tactic** represents the adversary's tactical objective, such as obtaining initial access, establishing persistence, collecting information, or creating impact.

A **technique** describes how that tactical objective may be achieved.

ATT&CK provides a shared language for penetration testing, adversary simulation, threat modeling, detection engineering, incident investigation, and defensive monitoring.

8.5 How the Frameworks Complement Each Other

Framework	Primary Viewpoint	Main Question
PTES	Penetration-testing process	How should the assessment be conducted?
Cyber Kill Chain	Attack progression	Where is the attacker in the intrusion lifecycle?
MITRE ATT&CK	Adversary behavior	What tactics and techniques are being used?

Table 5: Comparison of PTES, Cyber Kill Chain, and MITRE ATT&CK [5, 9, 10].

9 Threat Modeling and Risk Management

Threat modeling is a structured process for examining how a system could be attacked before those attacks occur. It encourages security professionals to think about system design, assets, trust relationships, possible threats, and appropriate controls before weaknesses are exploited [11].

A simplified workflow is:



Figure 9: Threat-modeling workflow from asset identification through architecture, trust boundaries, threat identification, risk evaluation, controls, and residual risk [11].

9.1 Trust Boundaries

A trust boundary exists whenever data, users, processes, or systems move between environments with different levels of trust or authority.

Examples include:

- communication between the Internet and an internal application;
- transitions from a standard user to an administrator;
- communication between an application server and a sensitive database.

Security assumptions frequently change across trust boundaries, making them important locations for security analysis.

9.2 Risk Management

Risk management is the continuing process of identifying security risks, evaluating their significance, selecting appropriate responses, and monitoring the exposure that remains.

Organizations may choose to:

- mitigate risk;
- avoid risk;
- transfer risk;
- formally accept risk.

9.3 STRIDE

STRIDE provides a practical method for identifying common classes of threats.

Threat Category	Meaning
Spoofing	Impersonating a legitimate user, service, device, or system.
Tampering	Unauthorized modification of data, software, configurations, or messages.
Repudiation	Denying an action when the system lacks sufficient evidence to establish accountability.
Information Disclosure	Exposing information to an unauthorized person, process, or system.
Denial of Service	Preventing legitimate users from accessing a system, service, or resource.
Elevation of Privilege	Obtaining capabilities beyond those originally authorized.

Table 6: The STRIDE threat categories.

STRIDE also relates naturally to the CIA Triad. Tampering primarily threatens **Integrity**, Information Disclosure threatens **Confidentiality**, and Denial of Service threatens **Availability**.

9.4 PASTA

PASTA, the *Process for Attack Simulation and Threat Analysis*, is a risk-centric threat-modeling methodology that connects technical attack scenarios with organizational objectives and business impact.

It encourages practitioners to understand the system, identify threats and weaknesses, model credible attack scenarios, and evaluate the resulting risk.

For an introductory course, the important point is not to memorize every threat-modeling methodology but to understand the underlying principle: security decisions should be based on assets, realistic threats, likely impact, and appropriate controls.

10 Chapter Summary

Ethical hacking is a professional security activity founded on authorization, defined scope, technical competence, and responsible conduct. Its purpose is not simply to exploit systems but to identify weaknesses, demonstrate relevant security impact, and help organizations improve their defensive posture.

The key concepts introduced in this chapter form the foundation for the remainder of the course:

- Assets, threats, vulnerabilities, exploits, attack vectors, controls, and risk provide the basic vocabulary of cybersecurity.
- The CIA Triad defines the fundamental objectives of confidentiality, integrity, and availability.
- White Hat, Gray Hat, and Black Hat classifications distinguish hacking activity according to authorization and intent.
- Red, Blue, and Purple Teams represent offensive testing, defensive operations, and collaborative improvement.
- Modern attack surfaces include people, networks, applications, endpoints, identities, cloud platforms, APIs, suppliers, and third-party services.
- Vulnerability assessment identifies weaknesses, while penetration testing evaluates whether those weaknesses can produce meaningful security impact.
- Legal authorization, Rules of Engagement, and proper evidence handling are essential elements of professional penetration testing.
- PTES, the Cyber Kill Chain, and MITRE ATT&CK provide complementary perspectives on testing methodology, attack progression, and adversary behavior.

- Threat modeling and risk management help organizations anticipate weaknesses and apply appropriate controls before attackers exploit them.

Ethical hacking transforms an attacker's perspective into a controlled method for understanding and reducing security risk.

References

[1] M. N. Alam and V. Laxmi, Eds., *Ethical Hacking and Cybersecurity: A Comprehensive Guide to Penetration Testing and Threat Mitigation*. Dhaka, Bangladesh: BCRP, 2025.

[2] G. Weidman, *Penetration Testing: A Hands-On Introduction to Hacking*. San Francisco, CA, USA: No Starch Press, 2014.

[3] W. Easttom, *Computer Security Fundamentals*, 5th ed. Indianapolis, IN, USA: Pearson IT Certification, 2024.

[4] European Union Agency for Cybersecurity, "Enisa threat landscape 2025," ENISA, Heraklion, Greece, Tech. Rep., 2025.

[5] Penetration Testing Execution Standard. The penetration testing execution standard (ptes). [Online]. Available: https://www.pentest-standard.org/

[6] People's Democratic Republic of Algeria, "Law no. 09-04 of 5 august 2009 concerning specific rules for the prevention and combating of offenses related to information and communication technologies," 2009, see also Penal Code Article 394 bis, as amended by Law No. 24-06 of 28 April 2024.

[7] ——, "Law no. 18-07 of 10 june 2018 concerning the protection of natural persons in the processing of personal data," 2018, amended and supplemented by Law No. 25-11 of 24 July 2025.

[8] EC-Council. The five phases of ethical hacking. EC-Council. [Online]. Available: https://www.eccouncil.org/cybersecurity-exchange/ethical-hacking/ceh-learning-framework/

[9] Lockheed Martin. Cyber kill chain. [Online]. Available: https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html

[10] MITRE. Mitre att&ck: Enterprise tactics and techniques. [Online]. Available: https://attack.mitre.org/

[11] OWASP Foundation. Threat modeling. [Online]. Available: https://owasp.org/www-project-threat-modeling/